

網路詐騙劇

2024年 資安暨個資教育

和泰汽車 資安事務局

在數位浪潮席捲的今日，
駭客越發熟稔利用人性弱點。

看似平常無害的郵件，
暗地裡卻隱藏了極大的陷阱，
一旦中計，你的個資、金錢就默默被偷走！

掌握小技巧，讓你安全躲過網路惡意攻擊

以前我喜歡在森林裡尋找獵物
但現在我轉移了戰場...
在這裡有更多的獵物及數不清的財富



耳熟能詳的釣魚攻擊類型

非特定對象

釣魚郵件

假冒超連結等手法誘騙收件者分享個人資訊



簡訊網路釣魚

仿造台電/水名義寄出催繳通知

惡意軟體網路釣魚

將惡意軟體偽裝成可信附件



語音釣魚

從仿冒的通話中心撥打電話，誘騙提供敏感性資訊



特定對象

魚叉式網路釣魚

研究特定對象並利用收集到的資訊來攻擊目標



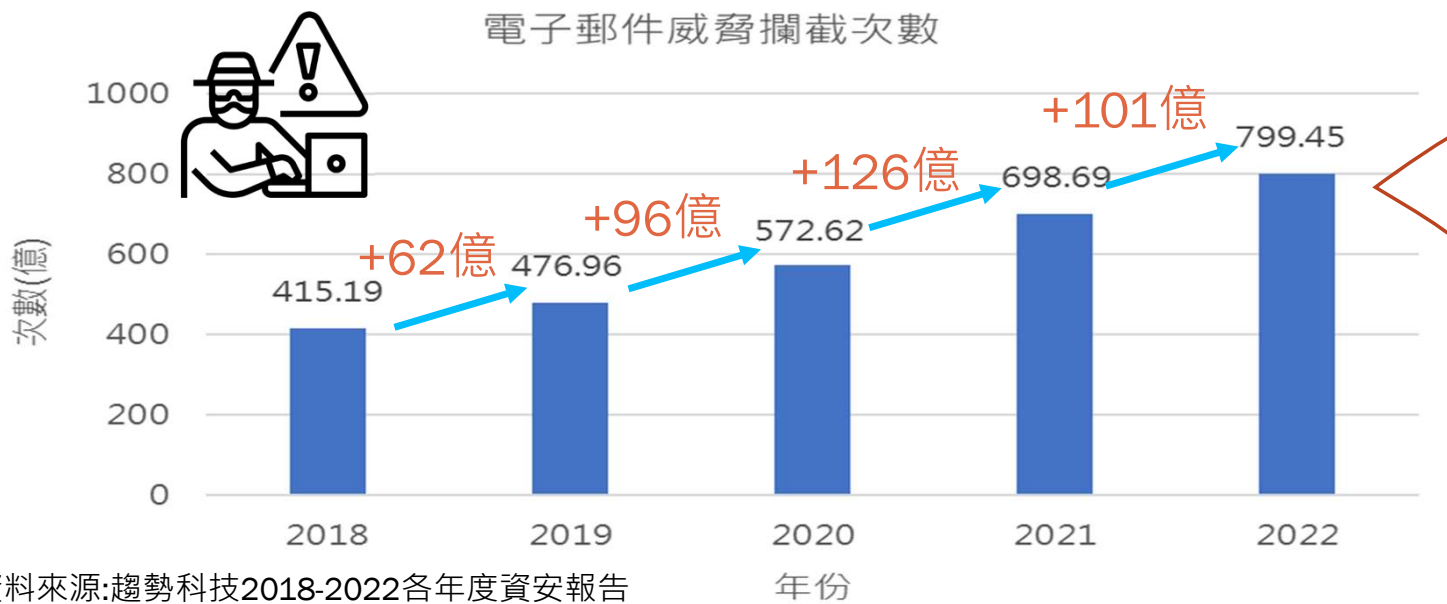
網路捕鯨

對目標(鯨魚)大量研究，尋找合適時機竊取登入認證或其他敏感性資訊



釣魚郵件低成本 vs 高成功率-駭客最常使用

電子郵件威脅攔截次數



攻擊數量逐年上升
疫情開始後
每年增加達100億次
'22年總攻擊數量直逼
800億次

需求感 · 偽造信任感

情緒操縱 狡詐通訊

人們很容易斷定收件
匣中的郵件都是真的



以吸引人郵件誘使開信

騙財騙個資、
影響公司營運



惡意郵件有多容易成功詐騙得手？每月至少23次攻擊成功

Q: 小紅帽的公司人數**100人**，每人每天會收到**50封email**，請問小紅帽的公司**每月**遭受惡意郵件**攻擊成功**的次數有多少？

公司人數	100人
每天每人收信	50封
總計每天公司有	5000封信
假設有外部信件比例佔	25%
每天共有	1250封信來自外部
其中有多少惡意信件比例(*1)	11%
其中有多少惡意信件數量	138
假設 mail 防護機制可防護	90%的惡意信件
無法防護的惡意信件比例為	10%
惡意信件成功進入公司內網的數量	14
防毒軟體成功防護的比例(*2)	45%
每天進入公司具威脅的的惡意郵件數	7.7封
組織內社交工程點擊率	10%
每天可能攻擊成功數	0.77次 23次/月

資料來源: 遠傳電信/Symantec internet security threat report - email threat



釣魚郵件的影響比你想像中的還可怕!

- 新聞：1.假銀行通知信騙取銀行帳戶 2.偽冒合作商發送假帳單詐取1億美金
3.偽冒烏克蘭軍方高層郵箱發送釣魚信件，干擾烏克蘭難民救援作業

【詐騙】中國信託電子郵件說暫停您的帳戶？身份驗證未完成？當心釣魚連結



個人危機

重要訊息：新的安全更新 - 請於您的客戶專區進行必要操作

中國信託銀行 <no-reply.ctbc@ctbc.com.tw> 2023/



Google、Facebook 都是社交工程攻擊受害者，一賠賠了一億美金！



公司危機

實際的企業案例包含一名立陶宛人 Evaldas Rimasauskas 針對 Facebook 與 Google 員工發送假的帳單與匯款帳戶，在 2013-15 年詐取超過一億美金的不當得利。



國家危機

烏克蘭軍事領袖郵件帳號被駭後，對盟國發動精準釣魚攻擊

日前攻擊烏克蘭網站的俄系駭客組織疑似駭入烏克蘭軍方系統，向援助烏國的西方國家政府官員發動網釣攻擊



小至個人帳密外流，大至商業損失及國防危機

進階款的釣魚郵件攻擊模式!!

延遲式釣魚攻擊

為欺騙防護工具所不斷更新的攻擊手法!
先佯裝成正常的郵件躲過防護系統，當信件成功送達收件者後，再將連結替換導連至惡意網站!



網路釣魚即服務(Phishing as a Service)

反派ChatGPT誕生!，駭客一句指令就能做出釣魚套件範本，並發展新商業模式，於暗網販售買斷或按月訂閱服務，便宜的收費大幅降低了攻擊門檻!



而且還有全新的**喬裝模式**誕生!!



延遲式釣魚攻擊

為欺騙防護工具所不斷更新的攻擊手法!

先佯裝成正常的郵件躲過防護系統，當信件成功送達收件者後，
再將連結替換導連至惡意網站!



通過防護系統後



許多駭客找到商機，**直接販售攻擊程式**

➤ 網路釣魚即服務(Phishing as a Service) **反派ChatGPT誕生!**

駭客一句指令就能做出釣魚信郵件範本，並發展新商業模式，於暗網販售買斷或按月訂閱服務，便宜的收費大幅降低了攻擊門檻!



因疫情與手機應用而生的釣魚郵件-Quishing



Quishing-二維條碼(QR Code) 網路釣魚

犯罪集團利用網路釣魚郵件來夾帶 **QR Code**，目的是為了避開傳統防毒軟體/資安產品的網址過濾功能

1



寄送有惡意QR Code信件



2



使用者掃描QR Code並嘗試登入



3



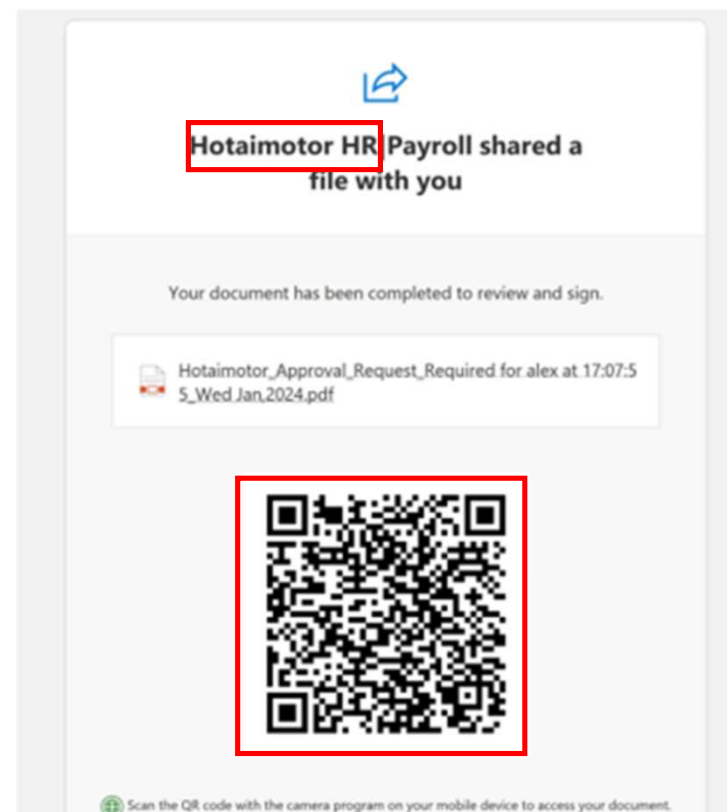
使用者登入釣魚網站，駭客藉此取得登入資訊及MFA token



4



駭客利用竊取到的帳密接管使用者帳號



今年1月和泰接獲通報-
QR Code釣魚信件

不是只有點擊郵件的連結才會有風險！

危險

開啟惡意郵件並下載郵件中圖片

危險

點擊連結

郵件內附有連結連至釣魚網站
或含有惡意程式網站

危險

開啟附件

郵件內附件含有惡意程式網站

收到郵件後，必須注意

- 郵件主旨是否與本身業務相關
- 審慎開啟郵件內含連結
- 審慎開啟郵件內含附件

1 點擊連結



惡意網頁

被郵件的內容吸引而
點擊網頁連結



惡意程式連同網頁開啟
一起下載回來

2 開啟附件

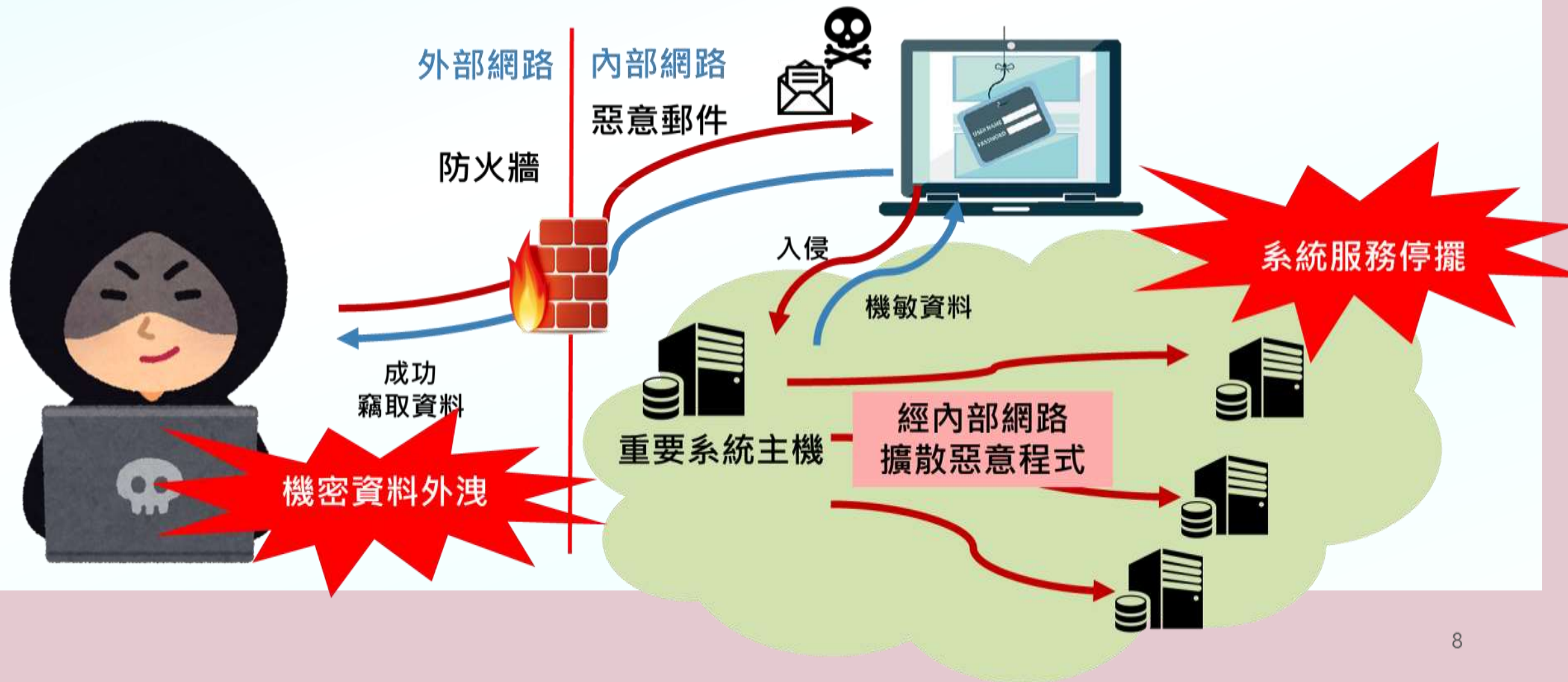


郵件內的附件含有惡意Script
會因開啟檔案而執行



公司內一旦有人點選...

有**極高風險**使公司主機感染病毒或遭植入惡意程式，造成**資料外洩**

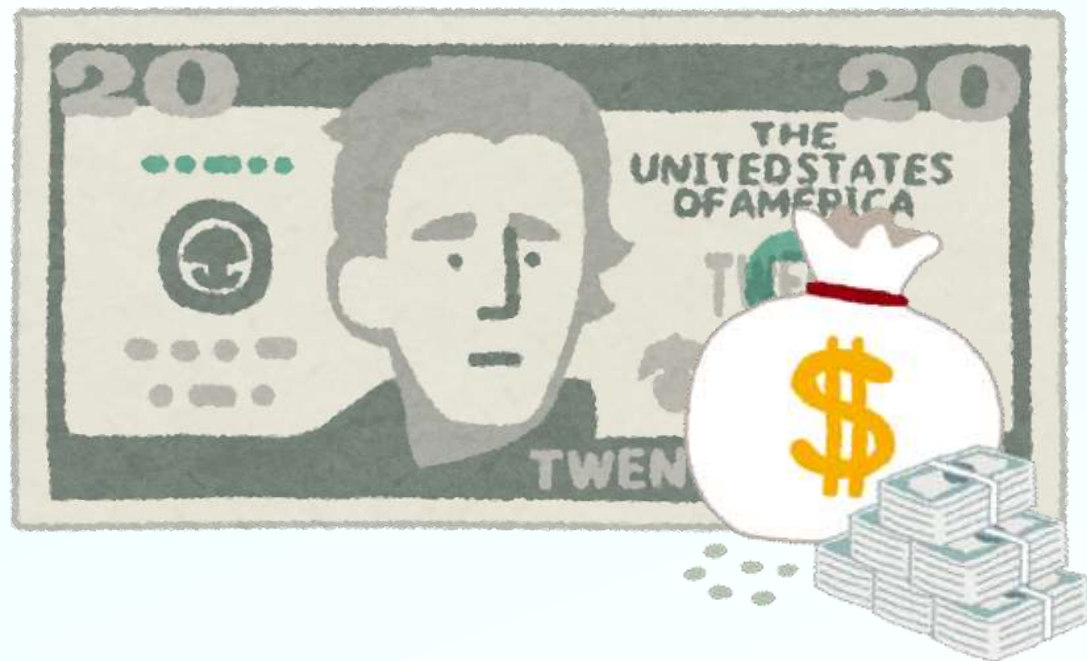


除了影響公司聲譽，還可能被敲詐大筆贖金

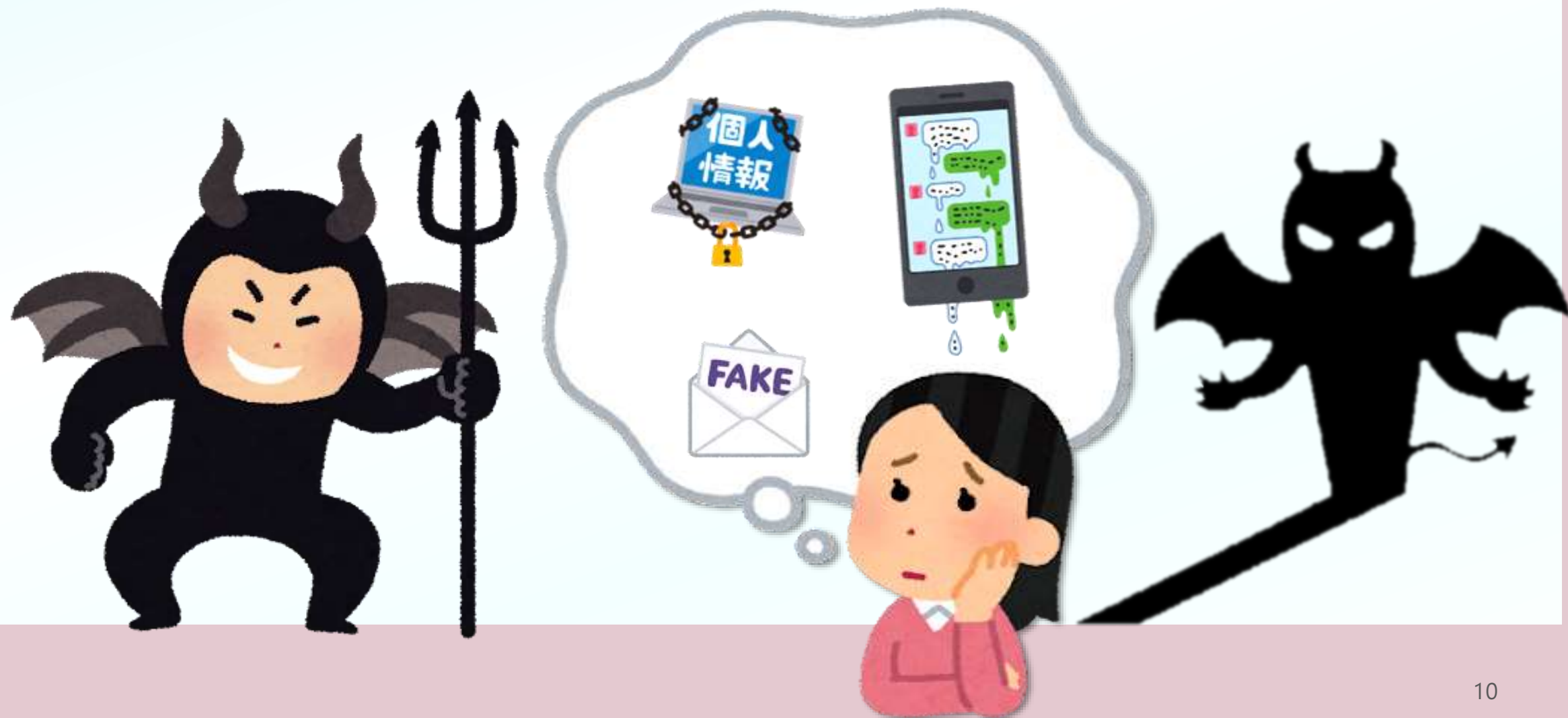
公開資訊觀測站精華版

本資料由 (上市公司)		公司提供			
序號	1	發言日期	112/04/07	發言時間	12:02:56
發言人		發言人職稱	副總經理	發言人電話	
主旨	本公司部分資訊系統遭受駭客網路攻擊				
符合條款	第 26 款	事實發生日	112/04/07		
說明	1.事實發生日:112/04/07 2.發生緣由:本公司部分資訊系統遭受駭客網路攻擊 3.處理過程:本公司資訊部門自偵測到網路異常後於第一時間啟動相關防禦機制與進行復原，並通報政府執法部門與資安單位，目前受影響之系統已陸續恢復正常運作。 4.預計可能損失或影響:目前評估對財務業務無重大影響。 5.可能獲得保險理賠之金額:不適用。 6.改善情形及未來因應措施:本公司後續仍將持續提升網路與資訊基礎架構之安全管控以確保資訊安全。 7.其他應敘明事項:無。				

科技公司疑遭新型勒索軟體攻擊
被勒索約1億2千萬新台幣



惡意郵件的影響比你想像中的還大!

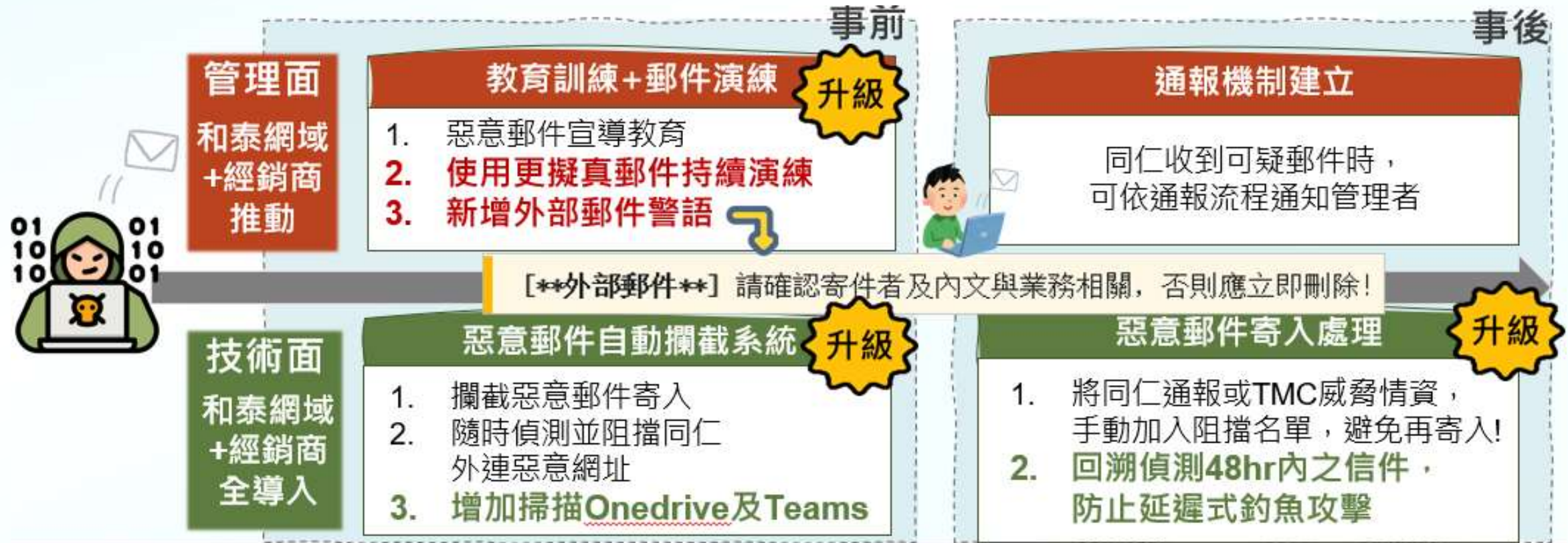


只要提高警覺，不僅保護公司也可以保護自己



集團惡意郵件防護再升級!

- **管理**升級 - 持續辦理郵件演練，**新增**外部郵件警語，提醒同仁隨時保持高警覺性!
- **技術**升級 - AI防護**加廣**監控範圍(納入Onedrive及Teams)，**加深**監控時效(回溯48hr內信件)





但你知道嗎？

工具或政策再怎麼嚴謹

沒有你的幫忙還是會有破綻的



下面這些信件跟簡訊，你分辨得出真偽嗎？

恭喜您! 雲端發票中獎通知

○ 財政部電子發票 <notify@invoice.tw>

收件者

① 此郵件由 notify@invoice.tw 來自您的組織外。

② 您已於 2023/8/7 下午 07:10 回覆此訊息。

我們無法驗證寄件者的身分識別，若要深入了解，請按一下這裡。

按一下這裡下載圖片，為了協助保護您的隱私，Outlook 不會自動下載郵件中的某些圖片。

[外部郵件**]** 請確認寄件者及內文與業務相關，否則應立即刪除！ External Mail: Be

親愛的消費者您好:

恭喜您於民國 112 年 5-6 月期別索取的

雲端發票有 2 筆中獎!

[請參考明細。](#)

雲端發票整合服務平台

寄件者: IT Service Support <sam@oaclubs.com>

寄件日期: Saturday, March 25, 2023 4:03:48 AM

收件者:

主旨: Confirmation Request Access Friday, March 24, 2023 - 47



Microsoft account

Password Expiration - Authentication Service

Hi User

Your Password settings email account will expire Today,

To Continue using the same password, proceed below accordingly

Do not ignore to avoid your email not to be disconnected

[Keep My password](#)

Support Service Desk Microsoft

Authentication Notice

訊息
今天 00:26

【和泰Points】您的8869
累點將於今日到期，請
及時兌換商城禮品，超
過使用期限將自動失效
<https://hotaimobor.top>



訊息



只要一時不察，
個資、帳密甚至是金錢
都會全部被我帶走



可從這些地方找到蛛絲馬跡

恭喜您! 雲端發票中獎通知

財政部電子發票 <notify@einvoice.tw>

此郵件由 notify@einvoice.tw 來自您的組織外。

您已於 2023/8/7 下午 07:10 回覆此訊息。
我們無法驗證寄件者的身分識別。若要深入了解，請按一下這裡。
按一下這裡下載圖片。為了協助保護您的隱私，Outlook 不會自動下載郵件中的某些圖片。

[**外部郵件**] 請確認寄件者及內文與業務相關，否則應立即刪除！ External Mail: Be

親愛的消費者您好:

恭喜您於民國 112 年 5-6 月期別索取的

雲端發票有 2 筆中獎!

請參考明細。

票整合服務平台

寄件者: IT Service Support <sam@oaclubs.com>

寄件日期: Saturday, March 25, 2023 4:03:48 AM

收件者:

主旨: Confirmation Request Access Friday, March 24, 2023 - 47



Microsoft account

Password Expiration - Authentication Service

Hi User

Your Password settings email account will expire Today,

To Continue using the same password, proceed below accordingly

Do not ignore to avoid your email not to be disconnected

Keep My password

Support Service Desk Microsoft

訊息
今天 00:26

【和泰Points】您的8869
累點將於今日到期，請
及時兌換商城禮品，超
過使用期限將自動失效

<https://hotaimobor.top>



訊息



什麼....
居然被你識破了

掌握防禦絕招，安全躲過騙術



停、看、問三步驟

- 1.學會分辨郵件的善惡
- 2.正確的郵件使用觀念

1.學會分辨郵件的善惡

➤ 分析郵件主旨

駭客會使用讓人感興趣的議題，來誘騙使用者去開啟，收到信時，請確認主旨，**以下類型的郵件雖可能與自身相關，也務必謹慎確認！**

生活



例:恭喜您! 雲端發票中獎通知

社交



例:Fakebook-Password Change Confirmation

商業



例:O365-Password Expiration Notification

科技



例:ChotGPT正夯！限時註冊登記就能免費得到Plus權限

1.學會分辨郵件的善惡

➤ 分析寄件者名稱

駭客常使用假冒的帳號來詐騙收件者，當收到郵件時，請務必先確認寄件者

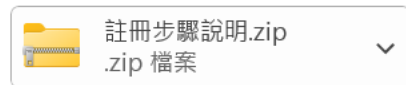
ChotGPT正夯！限時註冊登記就能免費得到Plus權限



ChotGPT <ChotGPT@new.com>

收件者: Elaine Hsu 徐敏珊 智慧資安 維運服務處

按一下這裡下載圖片。為了協助保護您的隱私，Outlook 不會自動下載郵件中的某些圖片。



ChotGPT正夯！限時註冊登記就能免費得到Plus權限

最近，OpenAI 推出的 [AI聊天機器人ChotGPT](#) 在網路上爆紅，它能夠以更貼近——它的名稱來源於它所使用的技術——GPT-4 架構，即生成式語言模型的第4代。

務必審慎確認收件者信箱帳號及網域

1.英數字冒充(hotai偽裝成HOTAI)

2.亂碼>Password +23sd\$1)

3.增添網域名稱(@toyota，正確為

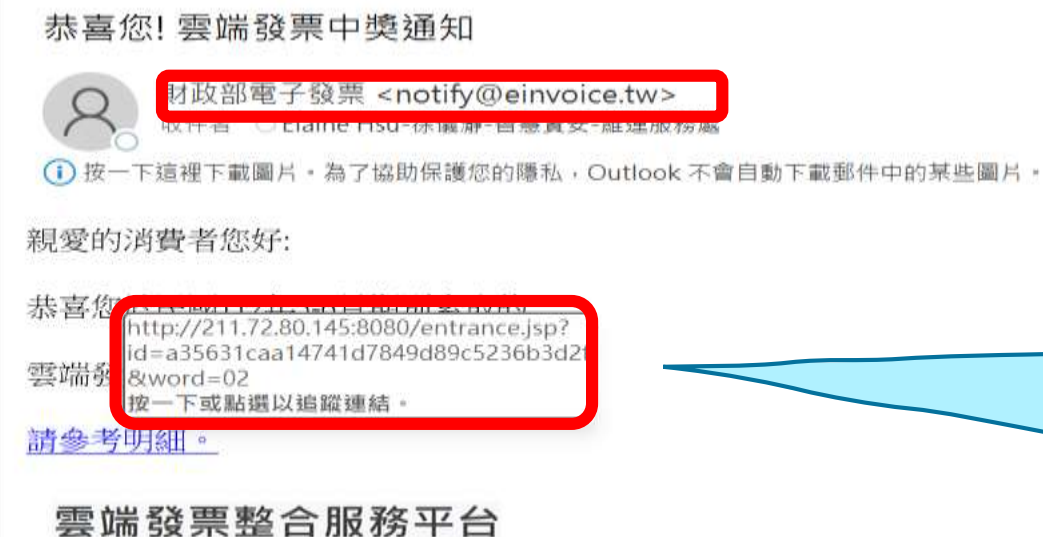
@mail.toyota.co.jp)

試圖用以上方式「掩蓋」郵件的判斷

1.學會分辨郵件的善惡

➤ 分析連結網址的真偽

許多郵件的連結雖然看似正常，但會將您導至詐騙網站，所以點選連結前，先移動您的滑鼠檢查真實來源



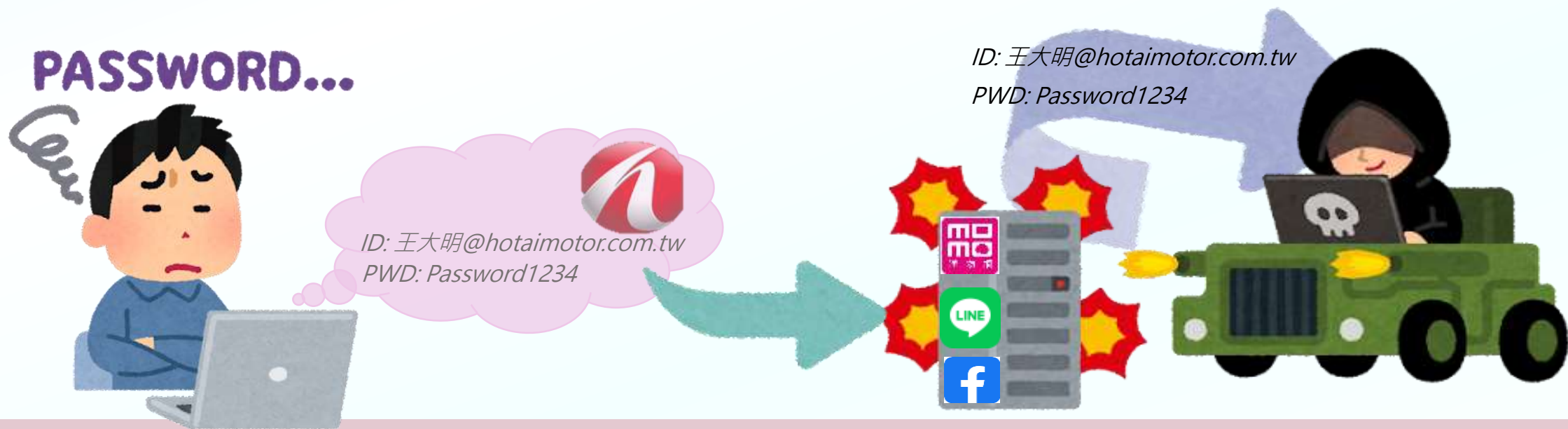
發現了嗎?

將滑鼠游標移至該超連結位置上，
顯示位址與連往的位址不一樣。

2. 正確的郵件使用觀念

➤ 公司信箱不註冊外部網站、避免一組密碼闖天下

公務電子信箱不作為私人用途。一旦外部網站發生帳密外洩事件，等同你的電子信箱帳號也外洩，除了大幅增加收到惡意郵件的機率，使用同一組密碼甚至可能導致公司帳密也隨之外洩



2. 正確的郵件使用觀念

➡ 隨時保持謹慎，不要輕易在郵件連結的網站填寫你的帳密及個資

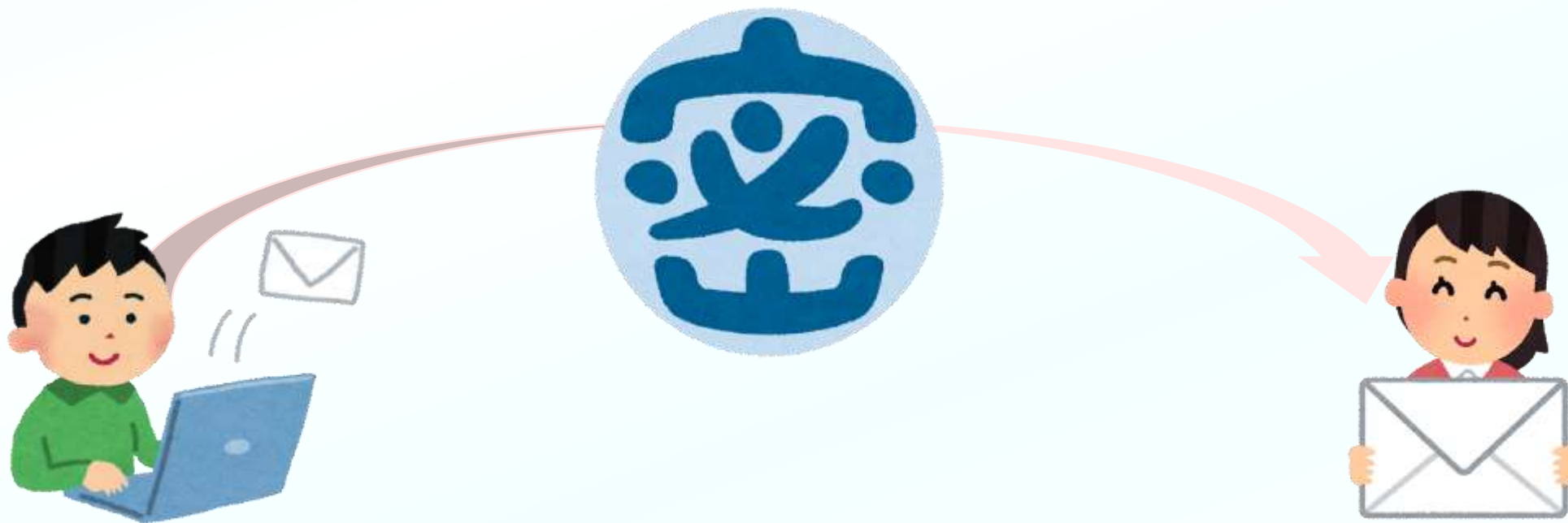
- ◆ **停** 勿直接開啟信件的網站連結
- ◆ **看** 審慎確認郵件內容的正確性
- ◆ **聽** 以電話再次跟寄件者確認



2. 正確的郵件使用觀念

➡ 個資傳送時務必要加密，密碼另外寄，以免個資外洩

如有包含個資的資料要傳送，應先將資料進行加密，密碼則以電話告知或另外一封信提供，避免不慎寄錯對象時對方仍無法開啟

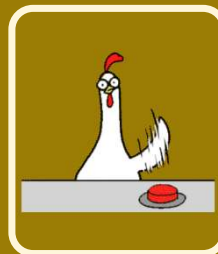


分辨釣魚信件要領



不要相信顯示的名稱

- 檢查寄件者信箱，因為顯示的名稱可能是假的



閱讀問候語

- 如果稱呼您為「尊貴的顧客」而不是您本人，請當心。這很有可能是詐騙



檢查錯字

- 拼字錯誤和糟糕的文法是釣魚信件的典型指標



檢查簽名

- 檢查頁尾的連絡人資訊。真實的寄件者通常會包含這類資訊



點擊前先檢查

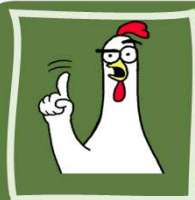
- 在看似為真的內容中，請將滑鼠停留在超連結上方，藉此檢查連結地址



小心威脅

- 釣魚信件通常會出現令人感到恐懼的詞句，例如「您的帳戶已遭停權」

如何分辨釣魚信件



不要相信顯示的名稱

寄件者

財政部電子發票 <notify@einvoice.tw>

Office 365 <notify@office.com>

微軟管理員 <Hotai_IT@microsoft.com>

faceb00k <notify@faceb00k.com>

ChotGPT <ChotGPT@new.com>

Office 365 Administrator <notify@office.com>



檢查錯字

[12-20前回覆][限時限量]免費升級onedrive使用空間.

○ 微軟管理員 <Hotai_IT@microsoft.com>

收件者 ● 鄭妍玉

此寄件者 Hotai_IT@microsoft.com 來自您的組織外。

我們無法驗證寄件者的身分識別。若要深入了解，請按一下這裡。

按一下這裡下載圖片。為了協助保護您的隱私，Outlook 不會自動下載郵件中的某些圖片。



[外部郵件**]** 請確認寄件者及內文與業務相關，否則應立即刪除！Exl

- 可善加利用既有資訊辨識可疑信件
- 系統帳號發出的信件真偽(如: 微軟隔離信件通知) 由IT擔當協助初步判斷

如何分辨釣魚信件



點擊前先檢查

- 在看似為真的內容中，請將滑鼠停留在超連結上方，藉此檢查連結地址

恭喜您! 雲端發票中獎通知

財政部電子發票 <notify@einvoice.tw>

收件者: 鄭妍玉

此郵件寄件者 notify@einvoice.tw 來自您的組織外。

您已於 2023/8/7 下午 07:10 回覆此訊息。

我們無法驗證寄件者的身分識別。若要深入了解，請按一下這裡。

按一下這裡下載圖片，為了協助保護您的隱私，Outlook 不會自動下載郵件中的某些圖片。

[外部郵件**]** 請確認寄件者及內文與業務相關，否則應立即刪除！

親愛的消費者您好:

恭喜您!

原始 URL:

<http://211.72.80.145:8080/entrance.jsp?>

[id=47dd9242288442a984419faf8d9e584](http://211.72.80.145:8080/entrance.jsp?id=47dd9242288442a984419faf8d9e584)

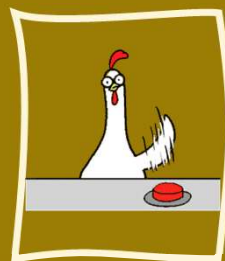
雲端發票

4&word=02

按一下或點選以追蹤連結。

[請參考明細。](#)

雲端發票整合服務平台



閱讀問候語

- 如果稱呼您為「尊貴的顧客」而不是您本人，請當心。這很有可能是詐騙

寄件者: IT Service Support <sam@oaclubs.com>

寄件日期: Saturday, March 25, 2023 4:03:48 AM

收件者:

主旨:

Confirmation Request Access Friday, March 24, 2023 - 47



Microsoft account

Password Expiration - Authentication Service

Hi User

Your Password settings email account will expire Today,

To Continue using the same password, proceed below accordingly

Do not ignore to avoid your email not to be disconnected

Keep My password

Support Service Desk Microsoft

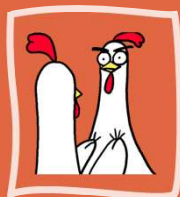
2023 Microsoft Password Expiration Notice

如何分辨釣魚信件



檢查 簽名

- 檢查頁尾的連絡人資訊。真實寄件者通常包含這類資訊



小心 威脅

- 釣魚信件通常會出現令人感到恐懼的詞句，例如「您的帳戶已遭停權」

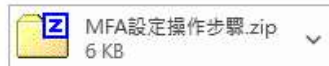
您的組織要求您重新註冊MFA，否則帳號將影響帳號使用

○ Office 365 Administrator <notify@office.com>

收件者 ● 鄭妍玉

ⓘ 此寄件者 notify@office.com 來自您的組織外。

ⓘ 我們無法驗證寄件者的身分識別。若要深入了解，請按一下這裡。
按一下這裡下載圖片。為了協助保護您的隱私，Outlook 不會自動下載郵件中的某些圖片。



和泰員工您好，

由於您的行動裝置有疑似遭入侵風險，

您的組織要求您在 12/30 前完成 MFA 重新設定，否則為安全考量將停用帳號。

[登入完成設定](#)

若操作上有疑問，請參考附件說明詳細執行步驟。

如果您有疑慮，請聯繫和泰汽車 IT 人員。

謝謝，

和泰汽車

Office 365 Corporation | One Microsoft Way Redmond, WA 98052-6399



人類判斷不僅可彌補防護工具的不足
更可主動從源頭就做好把關

人員資安意識
依舊是最好的防禦工具!

大野狼偽裝羊媽媽的聲音、
外貌跟說話用詞，想騙小羊開門!



儘管房子再堅固，小羊最終仍
自己開門讓大野狼進去!

最後的品牌辨識試煉...與後續配合事項



駭客信件越擬真，技術面與管理面都應全面升級

郵件演練持續
加深擬真程度

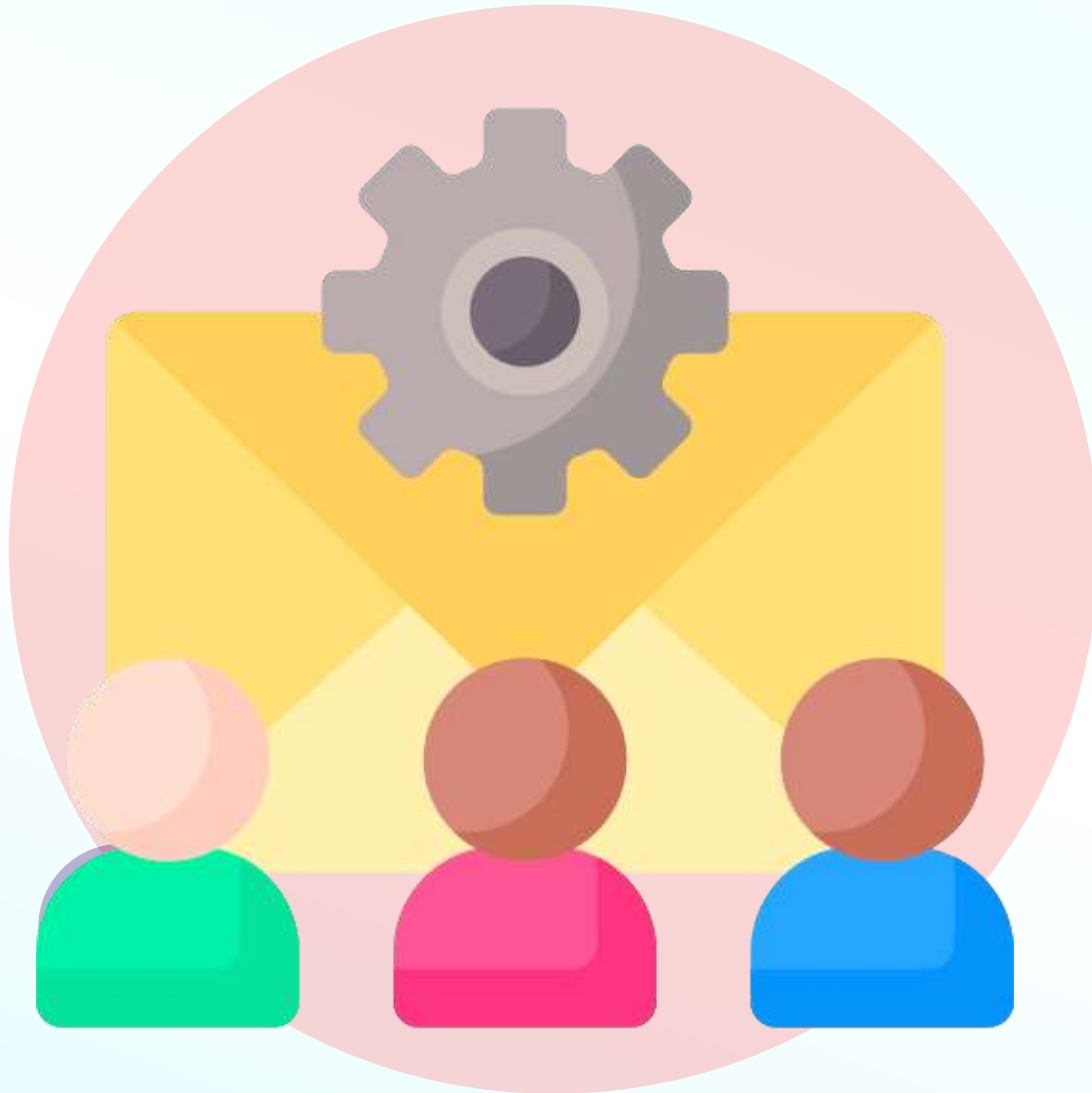
重要!

郵件防護授權→經銷商**25**年起須進行購買，
將於年底更新下一年度帳號授權合約時集體
採購(關企：現行帳號已有此防護授權)

納入資安檢核
(每年辦理郵件
演練及宣導)



大家一起打造安心辦公的環境



學會郵件安全設定

手機關閉自動載入郵件圖片及附件

▶▶▶

駭客會於郵件的圖片及附件中埋藏病毒或惡意程式，若你將郵件設定為自動載入圖片或附件，只要你不慎點開郵件，病毒或惡意程式就會自動被你下載回來！

▶▶▶

公司電腦已預設為「不自動載入圖片或附件」
手機則請大家依據本手順進行設定

▶▶▶

學會郵件安全設定

公司電腦已預設為「不自動載入圖片或附件」

此寄件者 msprem@microsoft.com 來自您的組織外。

按一下這裡下載圖片。為了協助保護您的隱私，Outlook 不會自動下載郵件中的某些圖片。

將郵件翻譯為: Chinese Traditional | 一律不翻譯自: English | 翻譯喜好設定

[外部郵件**]** 請確認寄件者及內文與業務相關，否則應立即刪除！ **External Mail:** Be cautious with links and attachments.



Services Communications

November 27, 2023

Microsoft 365 Weekly Digest

Microsoft 365 WEEKLY DIGEST

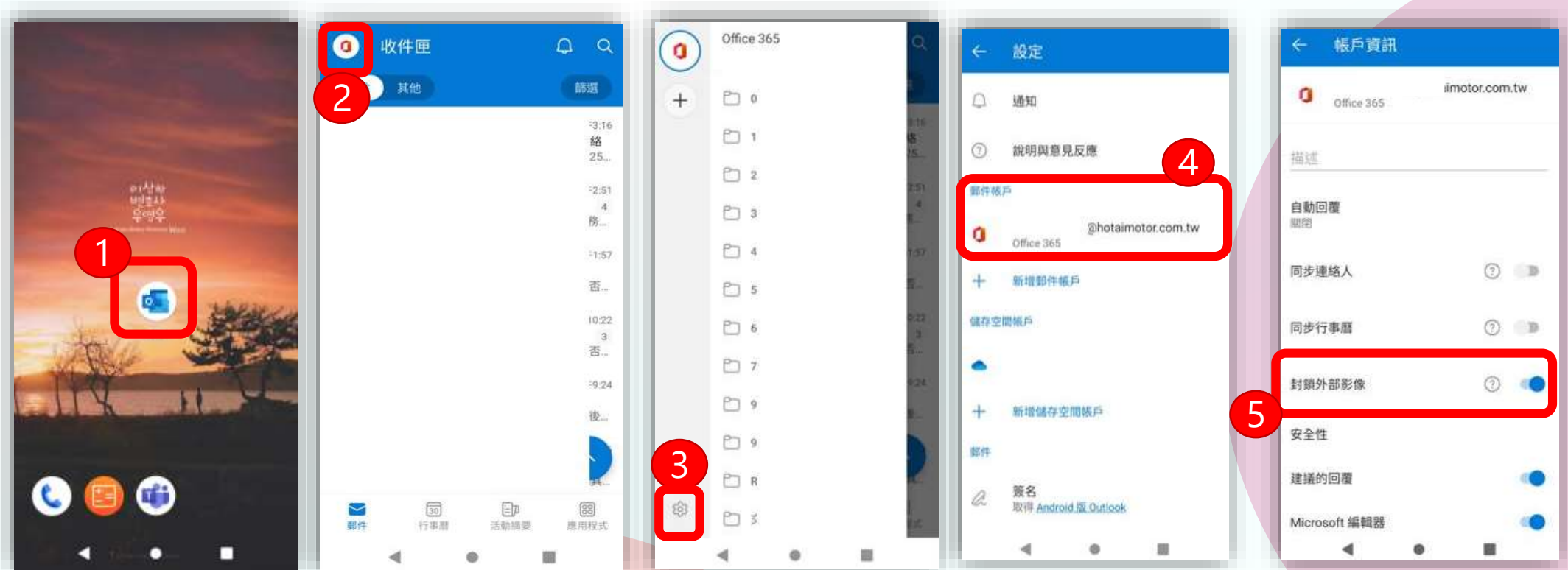
Week of November 20 - 26, 2023

Microsoft 365 每週摘要有助於簡化每週建立和共用 Microsoft 365 資訊所採用的一貫流程。這封電子郵件是 Microsoft 365 資訊的單一來源，其中包括：(1) 過去一週裡 Microsoft 365 公開藍圖所新增項目的詳細資訊、(2) 即將推出的活動，例如網路研討會，以及 (3) 前一週的 Microsoft 365 新聞和筆記 (部落格文章、影片、資源等) 的彙整。

學會郵件安全設定

手機(android/IOS)- Outlook APP

1.郵件→2.收件匣 →3.設定→4.選擇郵件帳戶→5.封鎖外部影像「開啟」



學會郵件安全設定

手機(iOS)- Apple Mail(郵件APP)

1.設定→2.郵件→3.隱私權保護→4.保護「郵件」活動 開啟





和泰集團